FPT UNIVERSITY

FPT UNIVERSITY

INFORMATION ASSURANCE

POLICY DEVELOPMENT IN INFORMATION ASSURANCE

Course:
Business Continuity Policy + BIA & RTO for Cloud Services (LMS/ERP)

Instructor: Hồ Hải

Group Members:
Phạm Hoàng Hải Nguyên – SE180511
Nguyễn Trúc Quỳnh – SE180280
Giả Thị Nhã Trân – SE180405

HCM, Spring 2026

Table of Contents

List Table **3**
List of Abbreviations **3**
Abstract **4**
1.Introduction **4**
Problem Statement 5
Research Objectives 5
Scope 6
2.Literature Review **6**
Business Continuity Planning 6
Business Impact Analysis Methodology 6
RTO and RPO in Cloud Environments 7
Cloud Disaster Recovery Architecture and Threat Landscape 7
Regulatory Framework and Research Gap 7
3.Methodology **8**
Research Design 8
Organizational Context 8
BIA Priority Classification Model 8
RTO/RPO Determination Criteria 9
Table 1: BIA Priority Classification with RTO/RPO Standards 9
Limitations 10
4.Results **10**
Table 2: Complete BIA: 17 Business Functions of ABC Credit Union 10
Key Structural Findings 12
5.Discussion **12**
Scenario 1: LockBit 3.0 Ransomware Attack 12
Table 3: Ransomware Incident — BIA-Tiered Impact and DRP Actions 13
Scenario 2: AWS us-east-1 Regional Outage 13
Table 4: Cloud Outage Incident — BIA-Tiered Impact and DRP Actions 14
BCP Policy Definition 14
Policy Statement 14
Purpose 15
Scope 15
Standards 15
Table 5: BCP Policy: RTO/RPO Standards 15
Procedures 15
Guidelines 16
Implications 16
6.Conclusion **17**
7.References **17**

List Table

Table 1: BIA Priority Classification with RTO/RPO Standards 9
Table 2: Complete BIA: 17 Business Functions of ABC Credit Union.....10
Table 3: Ransomware Incident — BIA-Tiered Impact and DRP Actions 13
Table 4: Cloud Outage Incident — BIA-Tiered Impact and DRP Actions 14
Table 5: BCP Policy: RTO/RPO Standards 15

List of Abbreviations

Abbreviation	Definition
AD	Active Directory
APA	American Psychological Association
BCP	Business Continuity Plan
BIA	Business Impact Analysis
CDP	Continuous Data Protection
CDN	Content Delivery Network
CISO	Chief Information Security Officer
DRP	Disaster Recovery Plan
ERP	Enterprise Resource Planning
FFIEC	Federal Financial Institutions Examination Council
LMS	Learning Management System
MFA	Multi-Factor Authentication
NCUA	National Credit Union Administration
NIST	National Institute of Standards and Technology
PCI-DSS	Payment Card Industry Data Security Standard
RPO	Recovery Point Objective
RTO	Recovery Time Objective
SaaS	Software as a Service
SLA	Service Level Agreement
SMFI	Small-to-Medium Financial Institution

Abstract

Financial institutions increasingly migrate critical operational systems to public cloud platforms in order to improve scalability and operational efficiency. However, this transition introduces new continuity risks that traditional Business Continuity Planning (BCP) frameworks may not fully address. This study proposes a cloud-oriented BCP and Disaster Recovery Planning (DRP) framework for ABC Credit Union, a representative small-to-medium financial institution operating a hybrid cloud environment consisting of a Learning Management System (LMS) hosted on Amazon Web Services and an Enterprise Resource Planning (ERP) system deployed on Microsoft Azure.

The research applies a qualitative Business Impact Analysis (BIA) methodology aligned with guidance from National Institute of Standards and Technology SP 800-34 Rev.1 and International Organization for Standardization ISO 22301:2019, while adapting the classification framework used in the IS4560 Lab #7 materials from Jones & Bartlett Learning. Seventeen organizational business functions are identified and categorized into four priority tiers—Critical, Major, Minor, and None—and corresponding Recovery Time Objectives (RTO) and Recovery Point Objectives (RPO) are assigned.

The analysis reveals that nearly half of the evaluated functions fall into the Critical tier, requiring rapid recovery and minimal data loss. Key continuity risks include dependency on a single cloud provider and centralized authentication infrastructure that could act as organizational single points of failure. To evaluate the resilience of the proposed continuity strategy, two disruption scenarios—a LockBit 3.0 ransomware attack and a regional cloud service outage—are analyzed to determine recovery priorities and disaster recovery actions.

The findings are consolidated into a formal Business Continuity Policy that integrates BIA results with defined recovery objectives, providing a structured approach for maintaining operational resilience in hybrid cloud environments.

1.Introduction

Digital transformation has significantly reshaped the operational and continuity risk landscape of financial institutions. The adoption of public cloud platforms enables organizations to reduce infrastructure costs, improve scalability, and accelerate service deployment. However, cloud-based infrastructures also introduce new forms of systemic dependency, including reliance on shared provider infrastructure, vendor concentration, and centralized identity services. These dependencies

can create complex failure scenarios that traditional Business Continuity Planning (BCP) frameworks were not originally designed to address.

For small-to-medium financial institutions (SMFIs), service disruptions in cloud-hosted systems may lead to operational downtime, regulatory compliance risks, and potential financial losses. When critical services become unavailable due to cyberattacks or infrastructure outages, organizations must ensure that recovery strategies are clearly defined and aligned with acceptable downtime and data loss thresholds.

Two categories of cloud-hosted platforms are particularly important in the operational environment of financial institutions. Enterprise Resource Planning (ERP) systems support essential financial and administrative processes, meaning that service disruption can immediately affect organizational operations. In contrast, Learning Management Systems (LMS) are commonly used to manage employee training and regulatory compliance programs. While LMS outages may not cause immediate financial disruption, prolonged service interruptions can affect compliance obligations and organizational readiness.

Given these dependencies, financial institutions operating hybrid cloud infrastructures must evaluate the impact of service disruptions and define recovery objectives that ensure operational resilience. Business Impact Analysis (BIA), combined with Recovery Time Objectives (RTO) and Recovery Point Objectives (RPO), provides a structured approach for identifying critical business functions and establishing appropriate continuity strategies.

Problem Statement

A 2023 Gartner survey found only 35% of SMFIs had reviewed their BCP within the preceding 12 months, and fewer than 20% had modeled cloud provider outage as a recovery scenario. This gap is compounded by the evolution of ransomware: LockBit 3.0 and BlackCat variants now specifically enumerate cloud storage mounts and delete shadow copies within minutes of initial access, targeting the backup infrastructure that conventional recovery strategies depend on (CrowdStrike, 2024). A cloud-native BCP framework must explicitly model both provider concentration risk and identity-infrastructure compromise

Research Objectives

This study pursues four objectives: (1) conduct a systematic BIA classifying 17 business functions by priority tier and mapping IT system dependencies; (2) define measurable RTO/RPO standards for each tier and analyze architectural implications; (3) develop a formal BCP Policy Definition institutionalizing BIA findings as organizational governance; and (4) analyze two high-probability incident scenarios against the BIA structure to produce structured DRP response frameworks.

Scope

This study focuses on cloud-based application services supporting a hypothetical small-to-medium financial institution operating a hybrid cloud environment. The analysis primarily examines enterprise systems such as Learning Management Systems (LMS) and Enterprise Resource Planning (ERP) platforms.

The research concentrates on continuity planning at the application and service level. Physical infrastructure design and detailed financial loss modeling are outside the scope of this study. A qualitative BIA classification model is applied to determine recovery priorities and guide the development of continuity strategies.

2.Literature Review

Business Continuity Planning

Business Continuity Planning (BCP) focuses on developing strategies that enable organizations to maintain critical operations during and after disruptive events. The standard ISO 22301:2019 defines BCP as a structured process for preparing preventive measures and recovery procedures to ensure operational resilience. Similarly, guidance from NIST SP 800-34 Rev. 1 outlines a lifecycle approach to continuity planning, including policy development, business impact analysis, contingency strategies, plan testing, and ongoing maintenance.

Previous research also highlights that organizational factors play an important role in continuity planning. For example, studies show that governance structures, executive support, and cross-department coordination significantly influence recovery effectiveness, particularly in cloud environments where incident response often involves cooperation between IT teams, service providers, and management units.

Business Impact Analysis Methodology

Business Impact Analysis (BIA) is a key component of continuity planning that evaluates business functions and determines the potential consequences of service disruption. According to Hiles (2011), BIA helps organizations identify critical processes and establish recovery priorities by analyzing the operational impact of system failures.

Two common methodological approaches are used in BIA. Quantitative BIA estimates financial losses associated with disruptions, while qualitative BIA applies categorical priority levels to classify business functions based on their operational importance. In practice, qualitative approaches are often more feasible for small and medium-sized organizations where detailed financial impact data may not be available.

In this study, business functions are categorized into four priority levels—Critical, Major, Minor, and None—to determine recovery priorities and guide the development of continuity strategies.

RTO and RPO in Cloud Environments

Recovery objectives are commonly defined using Recovery Time Objective (RTO) and Recovery Point Objective (RPO). RTO specifies the maximum acceptable time required to restore a service after disruption, while RPO defines the maximum acceptable amount of data loss measured in time.

In cloud environments, service availability guarantees provided by cloud providers do not necessarily ensure that application-level recovery objectives are met. Cloud Service Level Agreements (SLAs) typically measure platform availability rather than the time required for organizations to restore their own applications and data.

Achieving very strict recovery requirements, such as RPO = 0, often requires synchronous data replication across multiple storage locations. While this approach can eliminate data loss, it may introduce higher latency and additional infrastructure costs. As a result, such configurations are typically reserved for the most critical business functions.

Cloud Disaster Recovery Architecture and Threat Landscape

Cloud DR architectures span a cost-RTO spectrum from backup/restore (lowest cost, longest RTO) to active-active multi-region (near-zero RTO, highest cost) (AWS, 2023). The shared responsibility model places physical infrastructure availability on the provider; data protection, identity management, and recovery automation remain the customer's responsibility—and the majority of documented cloud data loss events originate in the customer boundary (Chou, 2015). Modern ransomware campaigns specifically enumerate cloud storage mounts and delete shadow copies within minutes of initial access (CrowdStrike, 2024); where on-premises AD provides SSO to SaaS platforms, AD compromise cascades simultaneously across all SSO-dependent services. Cloud regional outages produce correlated failures within a provider region—the AWS us-east-1 December 2021 event simultaneously degraded EC2, RDS, Route 53, and CloudFront (AWS, 2021)—demonstrating that single-region concentration risk is not theoretical.

Regulatory Framework and Research Gap

The NCUA (2021) requires all federally insured credit unions to maintain documented, tested BCPs with annual board review. The FFIEC IT Examination Handbook (2019) specifies board-approved BCP policy, documented BIA, defined RTO/RPO metrics, annual testing, and third-party vendor dependency analysis. Existing cloud BCP research predominantly addresses large enterprises without distinguishing SaaS/IaaS recovery characteristics, and does not model SMFIs with hybrid

LMS/ERP architectures. The AD/identity provider as a cross-cutting dependency affecting multiple BIA tiers simultaneously has not been systematically modeled. This study addresses both gaps.

3.Methodology

Research Design

This study adopts a qualitative case study design following the approach described by Robert K. Yin, with ABC Credit Union used as the case unit. A case study approach is appropriate because the research focuses on contemporary operational risks in cloud-based systems and does not involve experimental control over events.

The analytical method applied is Business Impact Analysis (BIA). Each business function is evaluated based on three primary dimensions: operational impact on members and services, regulatory compliance implications, and potential financial consequences. Based on this assessment, business functions are classified into priority tiers that determine recovery requirements and continuity strategies.

Organizational Context

ABC Credit Union represents a hypothetical small-to-medium financial institution reflecting the operational characteristics of many regional credit unions. The organization maintains approximately 2,400 member accounts, employs 180 staff members, and operates three branch locations while relying primarily on cloud-based IT infrastructure.

The organization uses Amazon Web Services to host web applications, content delivery services, and DNS infrastructure. Core business systems, including enterprise resource planning and productivity platforms, are hosted on Microsoft Azure. The Learning Management System is delivered through the SaaS platform Docebo.

This hybrid cloud configuration reflects a realistic operational environment in which multiple business services depend on external cloud providers and centralized identity infrastructure.

BIA Priority Classification Model

To determine recovery priorities, business functions are categorized into four priority levels: Critical, Major, Minor, and None. This classification is based on the potential operational disruption, regulatory impact, and financial consequences associated with system failure.

The classification approach is consistent with continuity planning guidance provided by NIST SP 800-34 Rev. 1 and regulatory evaluation frameworks used in financial sector continuity

assessments. Each priority tier is associated with specific recovery objectives that guide the definition of Recovery Time Objectives (RTO) and Recovery Point Objectives (RPO).

RTO/RPO Determination Criteria

Recovery objectives are defined using Recovery Time Objective (RTO) and Recovery Point Objective (RPO), which represent the maximum acceptable service downtime and allowable data loss following a disruption. RTO specifies the target time required to restore a system or business function after an incident, while RPO indicates the maximum amount of data that can be lost, measured as the time interval between the last recoverable backup and the disruption.

In this study, RTO and RPO values are determined based on the priority classification assigned during the Business Impact Analysis. Business functions categorized as Critical require the shortest recovery times and minimal data loss tolerance due to their direct impact on organizational operations and service availability. Functions classified as Major allow slightly longer recovery windows, while Minor and None categories tolerate longer recovery periods and larger potential data gaps.

The determination of recovery objectives also considers system dependencies, service architecture, and the feasibility of implementing recovery mechanisms within a cloud environment. Systems supporting financial transactions, authentication services, and core operational platforms are assigned stricter recovery targets, while non-essential services are allowed more flexible recovery parameters. These criteria ensure that recovery strategies align with operational priorities while remaining technically and economically feasible within the organization's cloud infrastructure.

Table 1: *BIA Priority Classification with RTO/RPO Standards*

Priority	RTO	RPO	Classification Criteria
Critical	**≤ 8 hrs**	**0 hrs**	Disruption immediately threatens member financial assets, real-time regulatory obligations, or emergency communications. Zero data loss tolerable. Requires synchronous replication and hot-standby or active-active failover.
Major	≤ 24 hrs	≤ 8 hrs	Significant service degradation; organization can sustain degraded operations for one business day. Regulatory consequences are deferred but material if unresolved within RTO.
Minor	≤ 1 week	≤ 3 days	Operationally inconvenient but no direct member impact. Manual workarounds are feasible for the RTO duration.
None	≤ 1 month	≤ 7 days	Minimal operational impact. Recovery deferred until all higher-tier functions are fully restored.

Note. Tier definitions derived from Jones & Bartlett Learning (2013) Lab #7 and cross-validated against NIST SP 800-34 (2010). RTO/RPO values are the Lab #7 worksheet metrics.

Limitations

This study has several limitations that should be considered when interpreting the results. First, the priority classifications used iThis n the Business Impact Analysis are based on structured analytical judgment applied to a hypothetical organizational context rather than empirical loss data from real disruption events. As a result, the classifications represent plausible operational priorities rather than measured impact values.

Second, the recovery feasibility estimates used to define Recovery Time Objectives (RTO) and Recovery Point Objectives (RPO) are derived from industry documentation and general cloud service benchmarks rather than direct performance measurements in a production environment. Actual recovery performance may vary depending on system architecture, configuration, and operational conditions.

Finally, the study adopts a qualitative BIA approach that focuses on operational impact and recovery prioritization. While this method is suitable for evaluating continuity strategies in cloud-based systems, it does not include detailed financial loss modeling. Future research could extend this work by incorporating quantitative impact analysis to estimate the economic consequences of service disruptions more precisely.

4.Results

Application of the priority classification model to the 17 identified business functions of ABC Credit Union resulted in the Business Impact Analysis (BIA) shown in Table 2. The functions are organized according to their assigned priority tier—Critical, Major, Minor, and None—and then grouped by operational domain to reflect their role within the organization's overall system architecture.

Table 2: *Complete BIA: 17 Business Functions of ABC Credit Union*

Business Function	Tier	RTO	RPO	Primary IT Systems
Real-time voice communications (internal & external)	**Critical**	≤ 8 hrs	0 hrs	Cisco UCM VoIP PBX, Microsoft Teams, SBCs, PSTN failover, 4G/LTE backup
Email communications – store-and-forward	**Critical**	≤ 8 hrs	0 hrs	Exchange Online (M365), Azure AD, Route 53 MX, Proofpoint
DNS – internal and external IP communications	**Critical**	≤ 8 hrs	0 hrs	AWS Route 53 (primary), Cloudflare DNS (secondary), AD DNS, DHCP

Internet connectivity	**Critical**	≤ 8 hrs	0 hrs	Dual-ISP WAN (BGP failover), SD-WAN, Palo Alto firewall cluster, CDN
Member self-service portal – account access	**Critical**	≤ 8 hrs	0 hrs	AWS ELB, React/Node portal, RDS PostgreSQL, CloudFront CDN, WAF
e-Banking / online transactions (24×7×365)	**Critical**	≤ 8 hrs	0 hrs	Core Banking API (Symitar), PCI-DSS payment gateway, PCI cloud segment
ERP – core financial operations (GL, AP, AR)	**Critical**	≤ 8 hrs	0 hrs	Oracle ERP Cloud Fusion, Azure SQL MI, Azure AD, SAP SuccessFactors
Real-time CRM customer service	**Critical**	≤ 8 hrs	0 hrs	Salesforce CRM, CTI, Verint call recording, IVR
Network management & IT support	**Major**	≤ 24 hrs	≤ 8 hrs	Splunk Cloud SIEM, SolarWinds NMS, ServiceNow ITSM, NOC dashboard
Member registration / sales orders	**Major**	≤ 24 hrs	≤ 8 hrs	Onboarding portal, Jumio ID verification, DocuSign, Salesforce
Payroll and human resources	**Major**	≤ 24 hrs	≤ 8 hrs	ADP Workforce Now, Oracle HCM Cloud, ACH payroll, benefits portal
LMS – mandatory regulatory compliance training	**Major**	≤ 24 hrs	≤ 8 hrs	Docebo LMS (SaaS/AWS), SCORM content, Azure AD SSO, NCUA audit log DB
Remote branch order entry to HQ	**Major**	≤ 24 hrs	≤ 8 hrs	Meraki SD-WAN, site-to-site VPN, Azure Virtual Desktop, branch ERP client
Voice & email to remote branches	**Major**	≤ 24 hrs	≤ 8 hrs	Microsoft Teams (branch), Exchange Online, branch SBCs, MPLS/VPN
Marketing & events management	**Minor**	≤ 1 week	≤ 3 days	HubSpot, Cvent, social media scheduler, CMS
Accounting reporting & regulatory filings	**Minor**	≤ 1 week	≤ 3 days	Oracle Analytics Cloud, CUNA reporting module, Power BI
Document management & records archiving	**None**	≤ 1 month	≤ 7 days	SharePoint Online, Azure Blob cold storage, Elasticsearch

Note. RTO/RPO values derived from Table 1 classification model. IT system mappings represent primary dependencies; failover/secondary systems described in Discussion.

Key Structural Findings

Three cross-functional findings emerge beyond the individual priority assignments in the Business Impact Analysis.

First, all eight Critical-tier functions share a common authentication dependency on Azure Active Directory and on-premises Active Directory services. This creates a structural vulnerability in which a failure of the identity infrastructure could simultaneously disrupt all Critical functions, resulting in a 47% organizational impact originating from a single infrastructure component.

Second, 11 of the 17 analyzed functions (64.7%) depend on services hosted within a single cloud region on Amazon Web Services (us-east-1). This concentration creates correlated failure exposure: a regional outage could simultaneously affect multiple systems, including five Critical-tier functions, highlighting a risk that is not immediately visible when evaluating business functions individually.

Third, 12 of the 17 functions (70.6%) rely on centralized authentication through Azure Active Directory and on-premises Active Directory, making identity infrastructure the most significant single point of failure within the system architecture.

Finally, the Learning Management System (LMS) is classified as Major rather than Critical because the consequences of its disruption are temporally deferred. While LMS outages do not immediately interrupt financial operations, regulatory training and compliance requirements may be affected over a days-to-weeks timeframe. This deferred-impact structure illustrates how certain systems may present significant organizational risk even when their operational effects are not immediately visible.

5.Discussion

Scenario 1: LockBit 3.0 Ransomware Attack

At 02:47, the organization's Security Information and Event Management (SIEM) system detects suspicious lateral movement within the internal network. By 03:15, the ransomware strain LockBit 3.0 has encrypted several critical systems, including ERP database volumes, on-premises backup servers, the LMS content database, and the on-premises Active Directory domain controller.

The compromise of the domain controller propagates through the identity synchronization service connecting the on-premises environment to Azure Active Directory. As a result, cloud-based single sign-on (SSO) authentication is disrupted across multiple enterprise services, including productivity platforms and cloud-based business applications. This incident illustrates the concentration risk associated with centralized identity infrastructure: a single authentication failure simultaneously disrupts 12 AD-dependent business functions, including 8 Critical-tier and 4 Major-tier services.

This scenario demonstrates that while per-function Recovery Time Objective (RTO) analysis is necessary for continuity planning, it may not fully capture systemic risks created by shared infrastructure dependencies. In environments where multiple services rely on centralized

authentication, continuity planning must also incorporate dependency-chain analysis to account for cascading failures across interconnected systems.

Table 3: *Ransomware Incident — BIA-Tiered Impact and DRP Actions*

Function	Tier	RTO	RPO	DRP Action
ERP Core Banking	Critical	8 hrs	0 hrs	Restore Oracle Cloud Fusion from immutable S3 Object Lock snapshot; engage Oracle P1 SLA; activate manual teller procedures.
AD / AAD Authentication	Critical	8 hrs	0 hrs	Rebuild on-prem AD from RODC snapshot in isolated VLAN; restore AAD Connect in separate tenant; force MFA re-enrollment on all accounts.
e-Banking Portal	Critical	8 hrs	0 hrs	Isolate portal from internal network; maintain CDN read-only mode for member access while write operations suspended pending AD restoration.
VoIP Communications	Critical	8 hrs	0 hrs	Activate PSTN analog fallback; failover to Teams Phone if Azure tenant unaffected; authorize personal mobile for key personnel.
LMS (Docebo)	Major	24 hrs	8 hrs	Docebo SaaS is cloud-isolated; disable compromised AD SSO; enable local Docebo authentication; restore content DB from vendor backup if affected.
Payroll / ADP	Major	24 hrs	8 hrs	ADP is external SaaS—protected from internal ransomware; bypass AD SSO by reissuing direct ADP credentials to HR team.

Note. AD restoration is the critical path for all SSO-dependent functions. Response sequence — Phase 1 Contain (0–30 min): segment VLANs, execute memory capture, preserve forensics, do not power off. Phase 2 Assess (30 min–2 hrs): enumerate encryption scope via EDR telemetry. Phase 3 Notify (within 2 hrs): CISO, CEO, Legal, Board; file FinCEN SAR per BSA/AML; notify FBI Cyber and CISA. Phase 4 Recover Critical tier (2–8 hrs): restore from immutable backups; do not pay ransom. Phase 5 Post-incident (within 72 hrs): root cause analysis, patch exploited vector, Board briefing.

Scenario 2: AWS us-east-1 Regional Outage

At 09:12, Amazon Web Services reports widespread service degradation in the us-east-1 region affecting several core services, including EC2, RDS, Route 53, and CloudFront. As a result, multiple customer-facing systems hosted in this region become unavailable, including the member portal, e-banking services, DNS infrastructure, and content delivery services.

In contrast, systems hosted on Microsoft Azure—such as the ERP platform and productivity services—remain operational. This partially validates the resilience benefits of a multi-provider architecture. However, the outage simultaneously affects several Critical-tier functions that depend on AWS-hosted infrastructure, requiring immediate recovery actions to restore service availability.

This scenario highlights the risks associated with regional concentration within a single cloud provider. Because multiple systems rely on the same infrastructure region, a provider-level outage can lead to correlated service disruptions across several business functions. The incident also demonstrates that meeting strict Recovery Time Objective (RTO) requirements—such as the eight-hour recovery target defined for Critical systems—requires preconfigured failover mechanisms and automated recovery processes. Attempting to configure recovery infrastructure during an ongoing outage would likely exceed acceptable recovery time limits.

Table 4: *Cloud Outage Incident — BIA-Tiered Impact and DRP Actions*

Function	Tier	RTO	RPO	DRP Action
DNS — Route 53 (affected)	**Critical**	8 hrs	0 hrs	Activate Cloudflare secondary DNS (TTL 60s pre-configured for Critical zones); update A records to failover IPs within 15 minutes.
Member Portal — AWS (affected)	**Critical**	8 hrs	0 hrs	Activate warm standby in AWS us-west-2 via pre-warmed CloudFormation IaC; RDS Multi-AZ replica in secondary region. Estimated failover: 45–90 min.
CDN — CloudFront (affected)	**Critical**	8 hrs	0 hrs	Reroute to Cloudflare CDN warm standby; update DNS CNAME to Cloudflare edge nodes; static content served from geo-distributed cache.
ERP / Teams / Exchange — Azure (unaffected)	**Critical**	N/A	N/A	UNAFFECTED by AWS outage. Confirm Azure connectivity from branch offices; staff process member transactions directly via ERP at branches.
LMS Docebo — AWS (affected)	**Major**	24 hrs	8 hrs	Docebo multi-region SaaS should auto-failover per vendor BCP; contact Docebo support; defer non-urgent training; document regulatory impact if unavailable >4 hrs.

Note. Response sequence — Phase 1 Detect (0–15 min): cross-reference NMS alerts with AWS Service Health Dashboard and third-party monitors. Phase 2 Communicate (15–30 min): notify CISO and IT Manager; post member notice on Cloudflare Pages static site independent of AWS. Phase 3 Failover (30–90 min): DNS, member portal, CDN. Phase 4 Monitor: verify RDS replication lag against RPO = 0; alert if replication gap exceeds 15 minutes. Phase 5 Failback: controlled return to us-east-1 post-recovery during low-traffic window; reconcile transaction data written to secondary region.

BCP Policy Definition

The findings of the Business Impact Analysis are formalized as part of the organization's Business Continuity Policy. The policy establishes governance requirements to ensure that critical business services remain available during disruptive events.

Policy Statement

ABC Credit Union shall maintain and enforce a Business Continuity Plan to ensure the continued availability of mission-critical systems. All business functions and supporting IT systems must undergo periodic Business Impact Analysis, and recovery objectives must be defined for each priority tier.

Purpose

The purpose of this policy is to provide a structured framework for identifying critical business functions, prioritizing recovery activities, and ensuring operational resilience during system disruptions.

Scope

This policy applies to all business functions, IT systems, employees, contractors, and cloud service providers associated with ABC Credit Union. It includes all cloud-hosted applications, authentication infrastructure, and supporting systems identified in the BIA.

Standards

Recovery objectives must be defined through measurable Recovery Time Objectives (RTO) and Recovery Point Objectives (RPO) for each priority tier. Cloud service providers and internal infrastructure must be configured to meet these recovery targets through appropriate backup, redundancy, and failover mechanisms.

Table 5: *BCP Policy: RTO/RPO Standards*

Tier	RTO	RPO	Technical Requirements
Critical	**≤ 8 hrs**	**0 hrs**	Active-active or hot-standby required. Cloud SLAs must contractually guarantee ≤ 8-hr RTO. RPO = 0 requires synchronous replication or CDP. All NCUA-regulated member-facing functions are Critical by definition.
Major	≤ 24 hrs	≤ 8 hrs	Warm standby or cloud auto-scaling recovery. Backups every ≤ 8 hours with verified restore capability. LMS outages during NCUA compliance deadlines must be risk-logged and escalated immediately.
Minor	≤ 1 week	≤ 3 days	Daily incremental backups; 3-day recovery window. Business units must maintain manual workaround procedures for the full RTO duration.
None	≤ 1 month	≤ 7 days	Weekly backups sufficient. Cold storage recovery acceptable. Systems restored after all higher-priority tiers are fully operational.

Note. Governing frameworks: NIST SP 800-34 Rev. 1 (2010), ISO 22301:2019, FFIEC BCP Handbook (2019). Annual SLA compliance review required.

Procedures

1. Annual BIA Review – The CISO conducts an annual Business Impact Analysis review with department heads, or whenever significant architectural changes occur.
2. Cloud SLA Alignment – IT Procurement performs annual reviews to ensure cloud service agreements support defined RTO/RPO requirements. Any gaps must be escalated to the CISO for remediation or formal risk acceptance.
3. Backup and Recovery Testing – Critical and Major systems must undergo weekly backup integrity verification and quarterly recovery testing. Critical-tier systems require an annual full-scale failover exercise.
4. Incident Classification – The IT Service Desk must classify incidents according to BIA tiers within 30 minutes. Critical incidents require immediate DRP activation, while Major incidents must be addressed within a 4-hour response window.
5. Documentation Retention – BIA reports, DRP testing results, SLA reviews, and policy updates must be stored in version-controlled repositories and retained for a minimum of 7 years.
6. Training – Annual BCP and DRP training must be delivered to personnel with recovery responsibilities through the organization's training platform.

Guidelines

Several operational challenges were identified during the BIA analysis.

First, 64.7% of business functions depend on a single AWS region, creating provider concentration risk. A phased multi-cloud or multi-region strategy for Critical-tier functions should be implemented within 18 months.

Second, achieving RPO = 0 requires synchronous replication, which may increase cloud infrastructure costs by approximately 30–40%. Therefore, investment should prioritize the most critical systems, including e-Banking, ERP, and DNS services.

Finally, the Learning Management System (LMS) is classified as Major due to its deferred regulatory impact. To mitigate compliance risk, mandatory regulatory training programs should include a minimum 15-business-day buffer relative to the 24-hour LMS RTO, ensuring training completion even if temporary outages occur.

Implications

Two theoretical insights emerge from this study. First, the qualitative four-tier BIA model remains applicable in cloud-based environments but should be complemented by cross-function dependency analysis. In particular, identity infrastructure such as Active Directory and Azure Active Directory must be treated as a critical infrastructure component with its own recovery objectives, as 70.6% of business functions depend on AD/AAD authentication. Second, the study highlights a deferred-consequence risk pattern for compliance-oriented systems such as LMS. Unlike operational systems that produce immediate disruption, LMS outages generate regulatory consequences over time, suggesting that current BIA frameworks may not sufficiently differentiate between immediate and delayed regulatory impacts.

From a practical perspective, three design principles can guide cloud-based business continuity planning. First, organizations should adopt an identity-first resilience strategy, as identity infrastructure failures can affect the majority of critical services simultaneously. Second, multi-region or multi-cloud architectures should be implemented for Critical-tier systems to reduce the risk of correlated regional outages. Third, organizations should deploy immutable backup storage mechanisms to protect against ransomware attacks that specifically target backup infrastructure, ensuring that recovery objectives remain achievable even during destructive attacks.

6.Conclusion

This study developed a Business Continuity and Disaster Recovery framework for a hybrid cloud environment supporting ERP and LMS services. The analysis identified several structural risks affecting operational resilience. First, 47% of business functions are classified as Critical, requiring RTO ≤ 8 hours and RPO = 0, and all of these functions depend on a shared authentication infrastructure. This creates a 47% organizational blast radius, making identity services the most significant single point of failure.

Second, 64.7% of business functions depend on a single cloud provider region, creating correlated outage risk that cannot be fully captured through per-function BIA analysis alone. This highlights the need for continuity planning that explicitly evaluates provider concentration and regional dependencies.

Third, the Learning Management System (LMS) demonstrates a deferred-consequence risk structure. While LMS outages do not cause immediate operational disruption, prolonged downtime may lead to regulatory compliance issues over time. This finding suggests that traditional BIA frameworks may not sufficiently differentiate between immediate and delayed regulatory impacts.

Overall, the results emphasize that identity infrastructure protection, multi-region deployment, and secure backup strategies are critical design priorities for cloud-based business continuity planning. Implementing geographically distributed authentication services, multi-region failover for Critical systems, and immutable backup storage significantly improves the ability to meet defined RTO and RPO targets.

Future research should focus on validating the proposed framework through empirical recovery testing and extending BIA methodologies to incorporate dependency analysis and temporal impact considerations for cloud-based systems.

7.References

Amazon Web Services. (2021). Summary of the AWS service event in the Northern Virginia (US-EAST-1) region. https://aws.amazon.com/message/12721/

Amazon Web Services. (2023). Disaster recovery of workloads on AWS: Recovery in the cloud. https://docs.aws.amazon.com/whitepapers/latest/disaster-recovery-workloads-on-aws/

Chou, D. C. (2015). Cloud computing risk and audit issues. Computer Standards & Interfaces, 42, 137–142. https://doi.org/10.1016/j.csi.2015.06.005

CrowdStrike. (2024). 2024 global threat report. CrowdStrike Holdings. https://www.crowdstrike.com/global-threat-report/

Federal Financial Institutions Examination Council. (2019). IT examination handbook: Business continuity management. https://ithandbook.ffiec.gov/it-booklets/business-continuity-management.aspx

Gartner. (2023). Business continuity management survey: Preparedness gaps in hybrid cloud environments. Gartner Research.

Herbane, B., Elliott, D., & Swartz, E. M. (2004). Business continuity management: Time for a strategic role? Long Range Planning, 37(5), 435–457. https://doi.org/10.1016/j.lrp.2004.07.002

Hiles, A. (2011). The definitive handbook of business continuity management (3rd ed.). Wiley.

International Organization for Standardization. (2019). ISO 22301:2019: Security and resilience — Business continuity management systems — Requirements. ISO.

Jhawar, R., Machanavajjhala, A., & Kamara, S. (2013). Fault tolerance and availability in cloud computing. In A. Bento & A. Aggarwal (Eds.), Cloud computing service and deployment models: Layers and management (pp. 121–148). IGI Global.

Jones & Bartlett Learning. (2013). Student lab manual: Laboratory #7: Identify necessary policies for business continuity — BIA & recovery time objectives (IS4560 Network Security). Jones & Bartlett Learning.

Microsoft. (2024). Azure business continuity and disaster recovery. https://learn.microsoft.com/en-us/azure/reliability/business-continuity-management-program

National Credit Union Administration. (2021). Letter to credit unions 21-CU-07: Interagency statement on cyber insurance and risk management. NCUA.

National Institute of Standards and Technology. (2004). FIPS Publication 199: Standards for security categorization of federal information and information systems. https://doi.org/10.6028/NIST.FIPS.199

National Institute of Standards and Technology. (2010). NIST Special Publication 800-34 Rev. 1: Contingency planning guide for federal information systems. https://doi.org/10.6028/NIST.SP.800-34r1

Sahebjamnia, N., Torabi, S. A., & Mansouri, S. A. (2015). Integrated business continuity and disaster recovery planning: Towards organizational resilience. European Journal of Operational Research, 242(1), 261–273. https://doi.org/10.1016/j.ejor.2014.09.055

Tari, Z., Yi, X., Premarathne, U. S., Bertok, P., & Khalil, I. (2015). Security and privacy in cloud computing: Vision, trends, and challenges. IEEE Cloud Computing, 2(2), 30–38. https://doi.org/10.1109/MCC.2015.45

Torabi, S. A., Rezaei Soufi, H., & Sahebjamnia, N. (2014). A new framework for business impact analysis in business continuity management. Safety Science, 68, 309–323. https://doi.org/10.1016/j.ssci.2014.04.017

Yin, R. K. (2018). Case study research and applications: Design and methods (6th ed.). SAGE Publications.